Incidentes de segurança em criptomoedas e contratos inteligentes

Sobre a base

- A base reúne **1.301 registros de incidentes de segurança envolvendo criptomoedas e contratos inteligentes**.
- Para esta análise, cada linha foi tratada como um registro de incidente.
- Os principais campos usados foram:
    - **data;**
    - **técnica registrada**
    - **e capital bruto drenado**, informado em dólares americanos (USD).

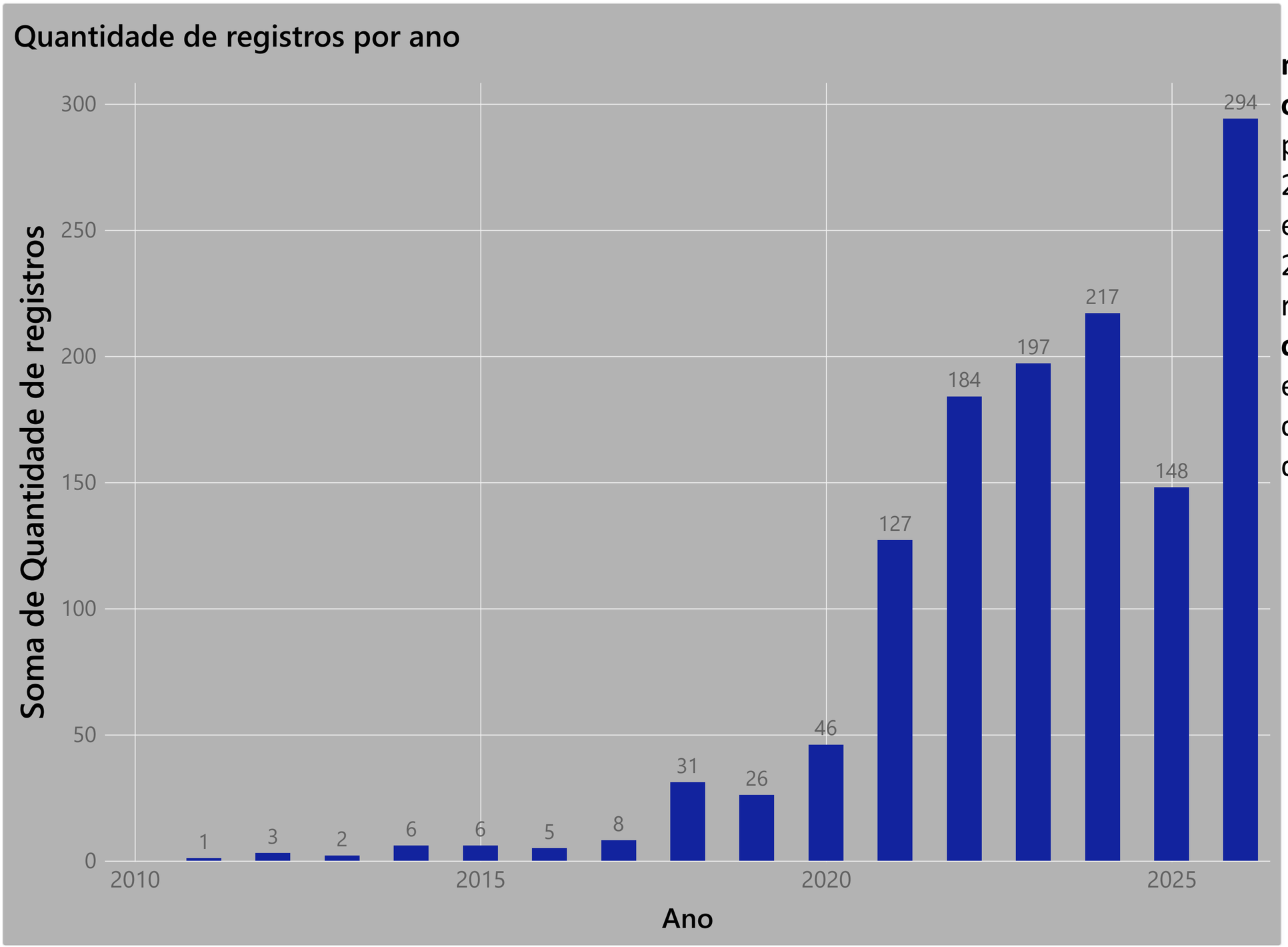
Fonte: Crypto & Smart Contract Hacks — Kaggle

O que é um contrato inteligente?

Um contrato inteligente (*smart contract*) é um programa executado em uma blockchain. Ele pode automatizar operações como empréstimos, trocas de criptoativos e transferências. Falhas no código ou nas permissões de acesso podem ser exploradas para desviar fundos.

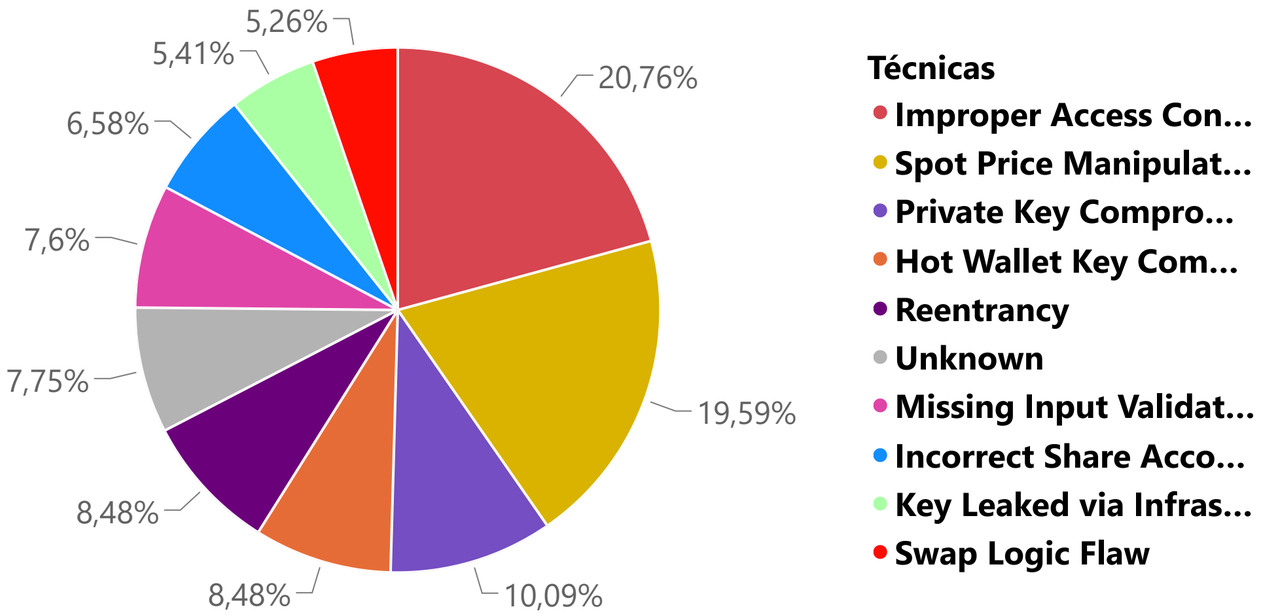
O que a análise investiga?

A análise compara o número de incidentes registrados por ano na base completa. Em seguida, identifica as **10 técnicas mais frequentes** e as classifica preliminarmente em **Bug presumido** e **Estudo caso a caso**. Por fim, compara o **capital bruto drenado** entre os grupos e calcula quanto o Top 10 representa no total da base.
Como os registros vêm de vários projetos, a base serve como **referência externa para orientar prioridades de prevenção**. Para avaliar as falhas específicas da empresa, seria necessário analisar também seus registros internos.



Os registros aumentaram no longo prazo, com oscilações. A contagem passou de 46 em 2020 para 217 em 2024, caiu para 148 em 2025 e chegou a 294 em 2026, o maior valor registrado na base. **A cobertura de 2026 é parcial**, então esse número corresponde ao período disponível.

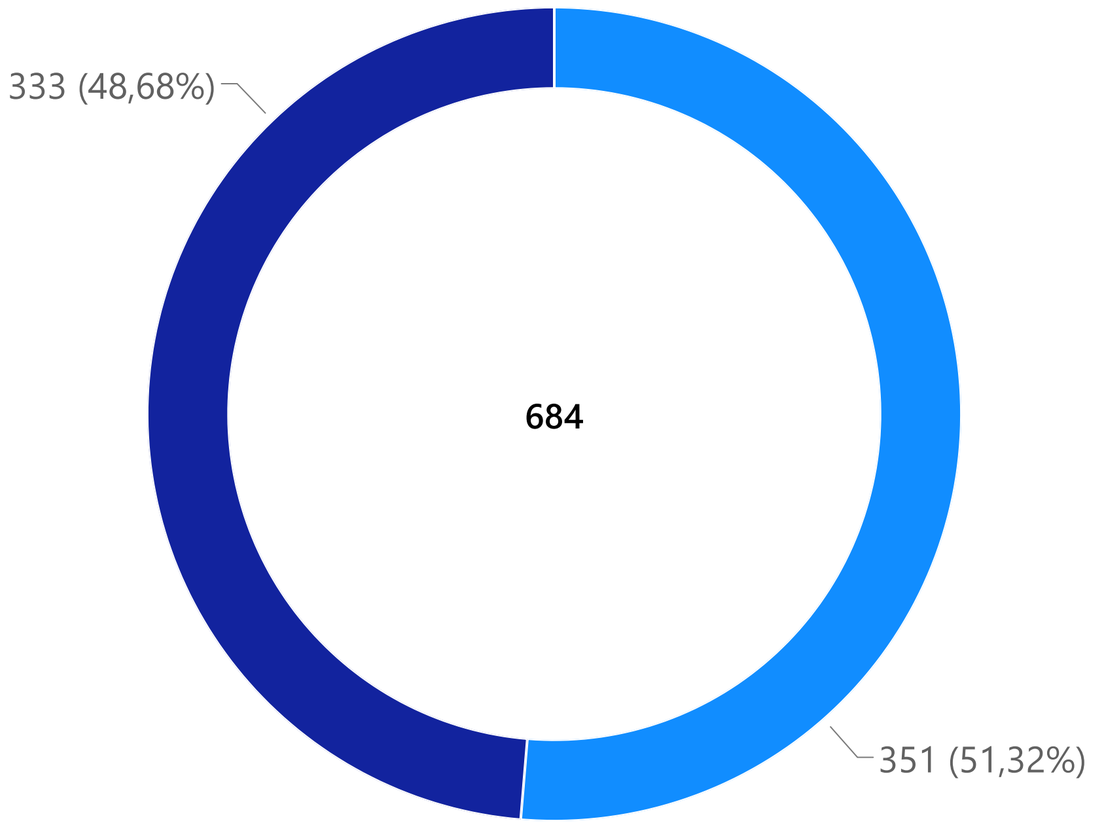
Técnicas utilizadas nos incidentes



As 10 técnicas mais frequentes somam **684 dos 1.301 registros da base (52,57%)**. As duas que mais aparecem são **controle de acesso inadequado**, com 142 registros, e **manipulação de preço à vista**, com 134.A partir do ranking, criamos uma **classificação preliminar própria** para as 10 técnicas mais frequentes. Marcamos como **Bug presumido** as técnicas que sugerem uma falha na lógica ou na implementação do sistema. As demais ficaram em **Estudo caso a caso**, pois a equipe de segurança precisaria investigar cada incidente para identificar a causa.

Com esse critério, **333 dos 684 registros do Top 10** ficaram em **Bug presumido** e **351** em **Estudo caso a caso**.

Classificação preliminar dos incidentes do Top 10



Classificação preliminar dos incidentes do Top 10

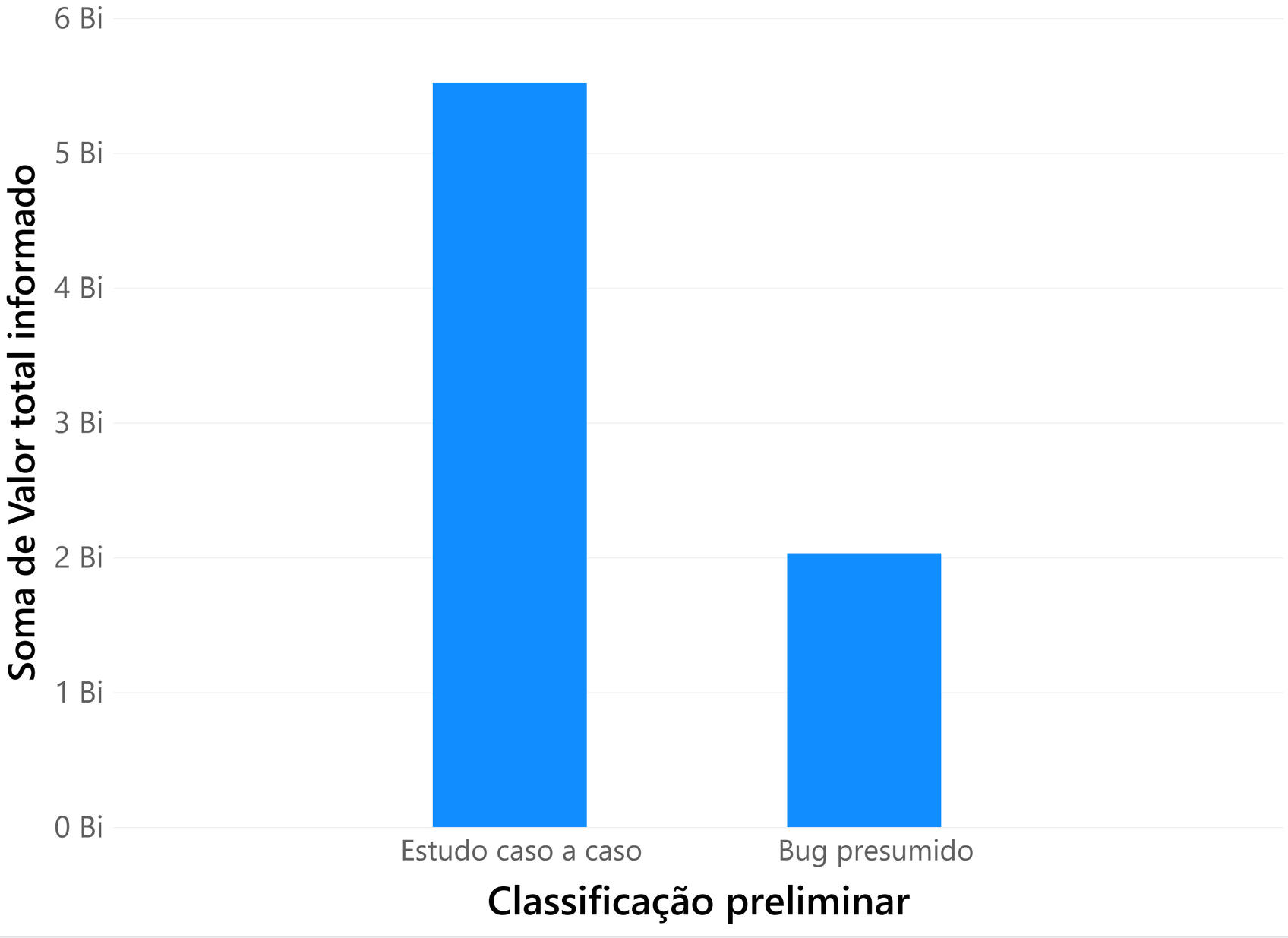
Criamos uma classificação própria para as **10 técnicas mais frequentes**, com base na técnica registrada em cada incidente.

- **Bug presumido — 333 registros (25,6% do total de registros)**. Técnicas que sugerem falhas na lógica ou na implementação do sistema.
- **Estudo caso a caso — 351 registros (26,98% do total de registros)**. Casos que exigem investigação individual pela equipe de segurança para determinar a causa.

Os percentuais se referem aos 684 registros do Top 10.

Prejuízo

Valor perdido por classificação



Os dois grupos tiveram quantidades parecidas de registros, mas o valor drenado foi bem diferente.

O grupo **Estudo caso a caso** somou **US$ 5,52 bilhões**, cerca de **2,7 vezes** os **US$ 2,03 bilhões** do grupo **Bug presumido**.

Juntas, as dez técnicas mais frequentes representam **52,57% dos registros** e **35,83% do capital bruto drenado** na base completa.

Plano de remediação

1. Investigar os casos de maior impacto
A equipe de cibersegurança deve analisar os incidentes do grupo *Estudo caso a caso* individualmente, começando pelos de maior valor drenado. Esse grupo somou **US$ 5,52 bilhões** no Top 10. O objetivo é identificar como cada incidente ocorreu e quais controles poderiam evitar que se repita.

2. Revisar os bugs presumidos
As equipes de desenvolvimento e segurança da plataforma devem verificar se as falhas sugeridas pela análise também podem ocorrer no próprio sistema. A primeira revisão deve focar nos **controles de acesso**, pois o controle de acesso inadequado foi a técnica mais frequente, com **142 registros**. A proposta é revisar permissões, testar operações críticas e corrigir as falhas confirmadas.